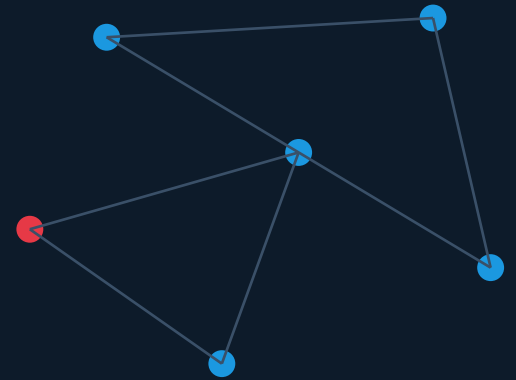




SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN

Trabajo práctico grupal

Ataques DoS y DDoS

Qué son, cómo funcionan y qué características los definen

Facundo Cantaberta · Federico Aieta · Bruno Martinez · Alvaro Rozas · Santiago Liveratore · Lucas Pennice · Ramiro Parisi

De qué vamos a hablar



01

Definición

Qué es DoS / DDoS



02

Características

Tipos y rasgos comunes



03

Casos conocidos

Historia y tres casos reales



04

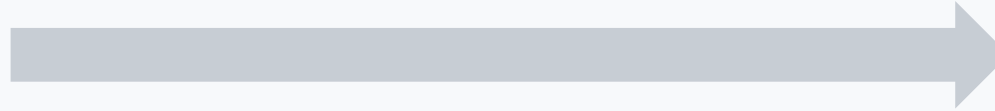
Mitigación y defensa

Arquitectura, tecnologías y buenas prácticas

¿Qué es un ataque DoS?



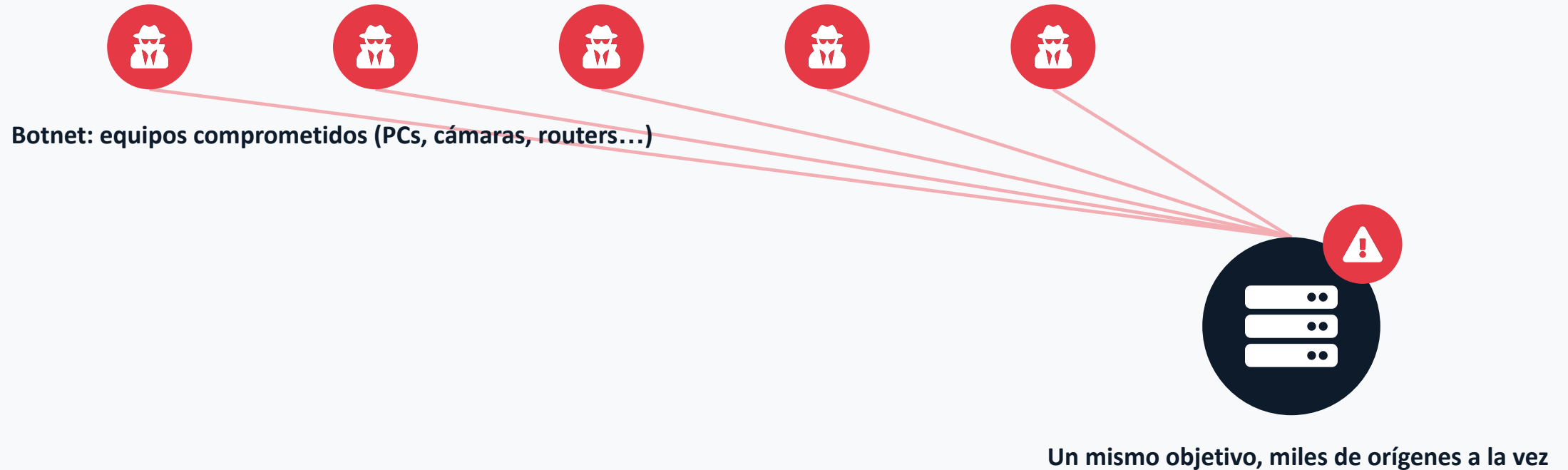
Atacante
(un solo origen)



Servicio saturado

DoS (Denial of Service): un único origen agota los recursos de un servicio para dejarlo fuera de línea.

¿Qué es un ataque DDoS?



DDoS (Distributed DoS): el mismo objetivo, pero el ataque llega distribuido desde una red de equipos controlados a distancia.

DoS vs. DDoS: la diferencia clave



DoS

Origen

Un único equipo

Volumen

Limitado

Rastreo del atacante

Más simple



DDoS

Origen

Miles de equipos (botnet)

Volumen

Muy alto

Rastreo del atacante

Muy difícil

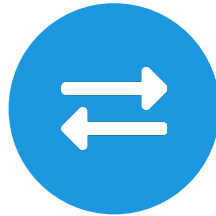
Tipos de ataque según la capa que afectan



Volumétrico

CAPA DE RED Y TRANSPORTE

UDP flood, amplificación DNS



De protocolo

CAPA DE TRANSPORTE

SYN flood, Smurf



De aplicación

CAPA DE APLICACIÓN

HTTP flood, Slowloris

Es habitual combinar varios vectores en un mismo ataque (ataque multivector).

Otros rasgos distintivos



Uso de botnets



Alcance global



Tráfico anómalo
y repentino



Ataques
multivector



Bajo costo
("DDoS por encargo")



Motivaciones
diversas

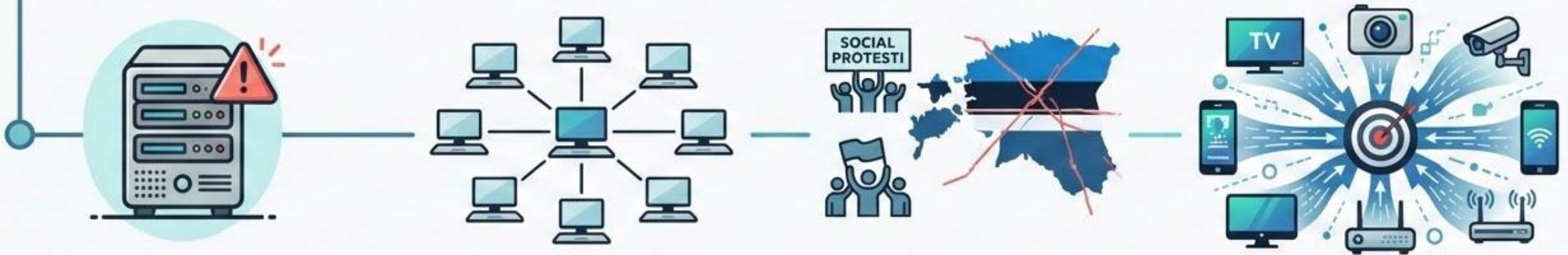
Breve historia: de Panix a las botnets

1996 | El origen (Panix): Primer ataque DoS documentado (SYN flood). Una sola máquina deja fuera de servicio a un ISP por varios días.

Fines de los 90 - 2000 | La era distribuida: Nacen herramientas como TRINOO. El ataque evoluciona a DDoS coordinando miles de equipos.

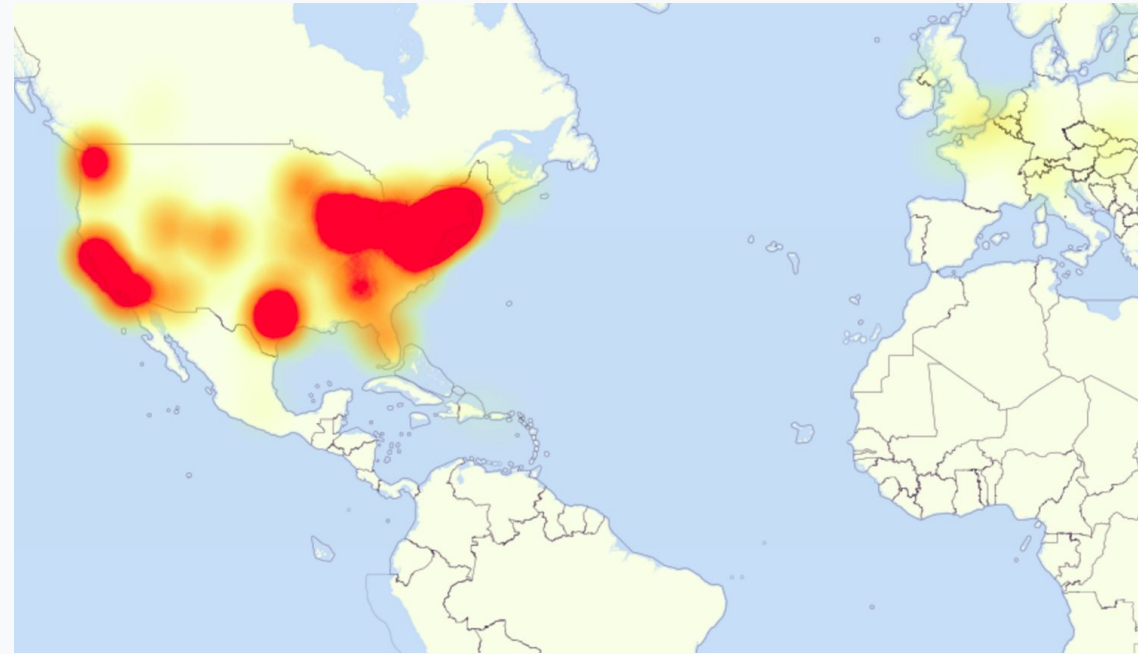
2000 - 2007 | Hacktivismo y Ciberguerra: De la protesta social al ataque a Estonia (2007): parálisis masiva de bancos, medios y gobierno.

Actualidad | La era de las Botnets: Dispositivos IoT e infraestructura masiva disparan los ataques a volúmenes récord (superando los 30 Tbps).



CASO 1: Caída de medio internet (Dyn + Mirai)

- ▶ 21 de octubre de 2016 alrededor de las 11:10 UTC, muchos sitios web quedaron inaccesibles
- ▶ **El objetivo fue Dyn**
- ▶ La botnet Mirai infectó unos 100.000 dispositivos IoT
- ▶ Los servidores como Spotify por ejemplo funcionaban perfecto. Simplemente nadie podía encontrar el camino hacia ellos (<https://www.spotify.com>).



CASO 1: Caída de medio internet (Dyn + Mirai)

Cifras y caso Amazon



1,2 Tbps

Pico de tráfico basura contra los servidores DNS (Kephart, 2016)



100.000 dispositivos

Cámaras, routers y DVR con credenciales de fábrica



Duración: 8 horas

En múltiples oleadas, desde las 11:10 UTC



Redundancia de DNS

Amazon resistió porque tenía un segundo proveedor de DNS

CASO 1: Caída de medio internet (Dyn + Mirai)

Lecciones del caso



Delegar el dominio en
proveedores



Cambiar contraseñas de
fábrica

3. CASOS CONOCIDOS

CASO 2: El ataque volumétrico más grande de la historia

- ▶ Fines 2025 - El ataque de **mayor fuerza bruta** jamás registrado en la historia de internet.
- ▶ Botnet hiper-volumétrica **Aisuru**.
- ▶ Red zombi compuesta por entre 1 a 4 millones de dispositivos IoT.
- ▶ Secuestro y uso masivo **Smart TVs (Android TV)**.



3. CASOS CONOCIDOS

CASO 2: El ataque volumétrico más grande de la historia

Métricas de la "Fuerza Bruta"



31.4 Tbps

Ancho de banda máximo registrado



14.1 Bpps

Intensidad de paquetes por segundo



Duración: 35 Segundos

Ráfagas cortas para evadir mitigación manual



Mitigación Autónoma

Filtrado perimetral con algoritmos de Machine Learning

CASO 3: Amplificación y daño colateral (Spamhaus, 2013)

- ▶ Marzo de 2013. Spamhaus incluye al hosting CyberBunker en su lista de bloqueo de spam y empieza el ataque.
- ▶ Reflexión y amplificación DNS: consultas de 36 bytes que devuelven respuestas de 3.000. Factor de amplificación cercano a 100x.
- ▶ Sin botnet propia: 750 Mbps del atacante se convirtieron en 75 Gbps promedio contra la víctima.
- ▶ Al no poder tumbar el sitio, atacaron aguas arriba. Hubo congestión en los puntos de intercambio de Londres, Ámsterdam y Frankfurt.

CASO 3: Amplificación y daño colateral (Spamhaus, 2013)

Cifras y lección del caso



300 Gbps

Pico reportado por un proveedor
Tier 1



Amplificación 100x

36 bytes de consulta, 3.000 bytes de respuesta



30.000 resolvers

Servidores DNS abiertos usados como
reflectores



BCP 38

Filtrado anti-spoofing: la defensa que sigue sin
aplicarse del todo

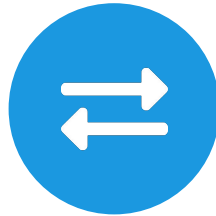
Los tres casos, uno al lado del otro



Spamhaus

2013

300 Gbps por amplificación. Sin botnet: alcanzó con resolvers abiertos de terceros.



Dyn / Mirai

2016

1,2 Tbps desde 100.000 dispositivos IoT con contraseñas de fábrica.



Aisuru / Kimwolf

2025

31,4 Tbps desde millones de Smart TVs, en ráfagas de 35 segundos.

El volumen creció cien veces en doce años, pero el arma fue siempre la misma: equipamiento de terceros mal configurado.

Estrategias de Mitigación y Defensa



01. Arquitectura y Diseño

- **Sobreaprovisionamiento**

- **Redundancia y Geodistribución**

- **Segmentación de Red (VLANs)**



02. Tecnologías de Mitigación

- **Enrutamiento Anycast (BGP)**

- **Firewalls de Aplicación (WAF)**

- **Filtrado Kernel (eBPF / XDP)**

- **CDNs y Scrubbing Centers**

Estrategias de Mitigación y Defensa



03. Buenas Prácticas

- **Gestión de Credenciales y Parches**

- **Cierre de Servicios Expuestos**

- **Planes de Respuesta a Incidentes (IRP)**

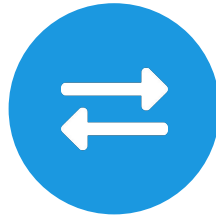
Tres ideas para llevarse



Disponibilidad

EL PILAR ATACADO

El DDoS no roba ni altera datos. Ataca que el servicio simplemente no esté.



Terceros

EL ARMA REAL

Resolvers, cámaras y televisores de gente que no sabe que está participando.



Arquitectura

LA DEFENSA

No hay bala de plata: distribuir, filtrar en el borde y no depender de un solo proveedor.

Contratar un ataque cuesta poco y no requiere conocimientos avanzados; resistirlo exige capacidad de red medida en terabits.